

SOLUCIÓN DE ARQUITECTURA PARA APLICACIÓN BANCARI

DESCRIPCIÓN DEL REQUERIMIENTO.

Diseñar un sistema de banca por internet, donde los usuarios podrán acceder al histórico de sus movimientos, realizar transferencias y pagos entre cuentas propias e interbancarias.

Toda la información referente al cliente se tomará de 2 sistemas: una plataforma Core que contiene la información básica de cliente, movimientos, productos; y un sistema independiente que complementa la información del cliente cuando los datos se requieren en detalle.

Debido a que la norma exige que los usuarios sean notificados sobre los movimientos realizados, el sistema utilizará sistemas expertos o propios de envío de notificaciones, mínimo 2.

Este sistema contará con 2 aplicaciones en el FRONT, una SPA y una aplicación móvil desarrollada en un Framework multiplataforma (Mencione 2 opciones y justifique el porqué de su elección).

Ambas aplicaciones autenticarán a los usuarios mediante un servicio que usa el estándar OAuth2.0, para el cual no requiere implementar toda la lógica, ya que la compañía cuenta con un producto que puede ser configurado para este fin; sin embargo, debe dar recomendaciones sobre cuál debe ser el mejor flujo de autenticación que se debería usar según el estándar.

Tenga en cuenta que el sistema de Onboarding para nuevos clientes en la aplicación móvil usa reconocimiento facial, por tanto, su arquitectura deberá considerarlo como parte del flujo de autorización y autenticación, a partir del Onboarding el nuevo usuario podrá ingresar al sistema mediante usuario y clave, huella o algún método otro método. Especifique alguno de los anteriores dentro de su arquitectura.

El sistema utiliza una base de datos de auditoría que registra todas las acciones del cliente y cuenta con un mecanismo de persistencia de información para clientes frecuentes, para este

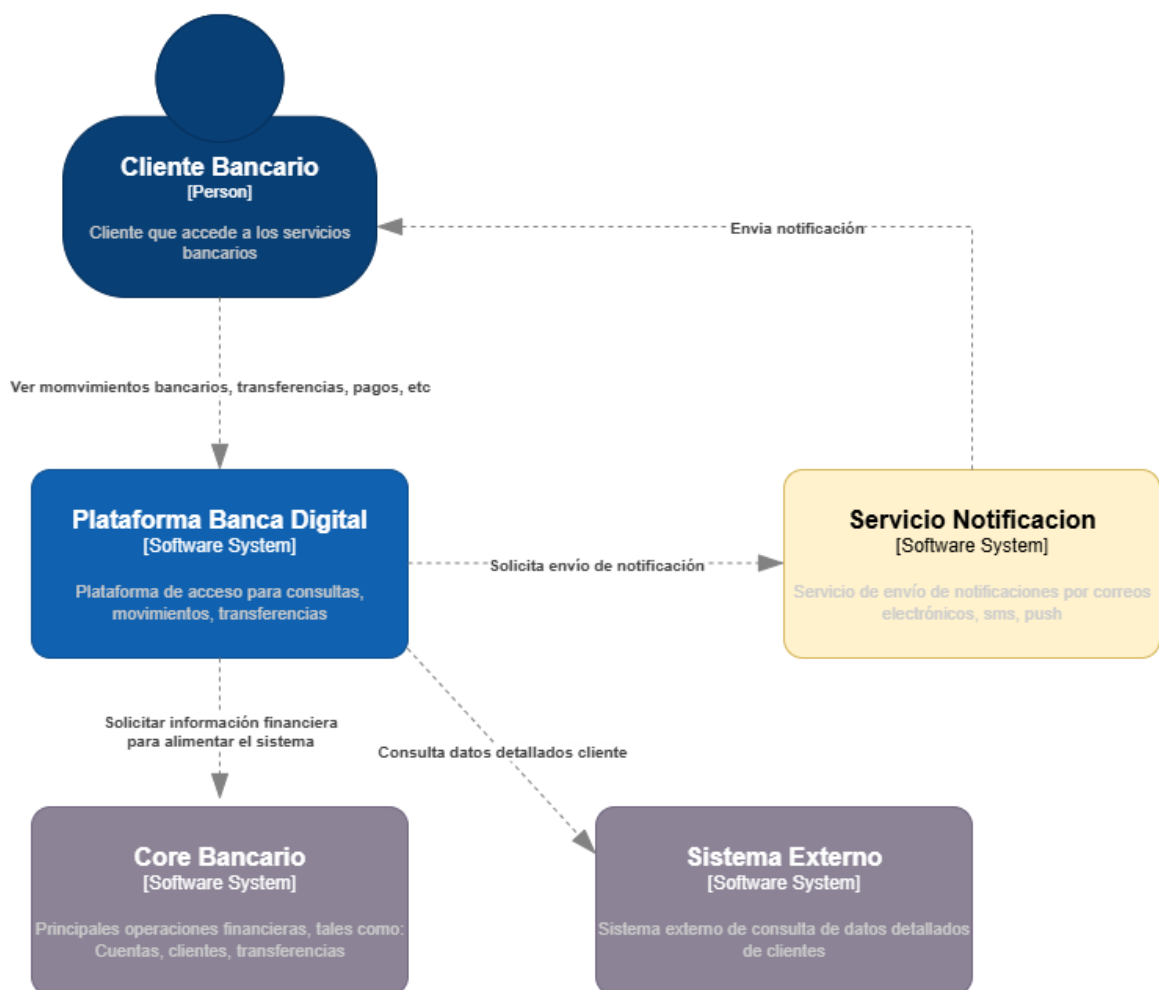
caso proponga una alternativa basada en patrones de diseño que relacione los componentes que deberían interactuar para conseguir el objetivo.

Para obtener los datos del cliente, el sistema pasa por una capa de integración compuesta por un Api Gateway y consume los servicios necesarios de acuerdo con el tipo de transacción. Inicialmente se cuenta con 3 servicios principales: consulta de datos básicos, consulta de movimientos y transferencias que realiza llamados a servicios externos dependiendo del tipo.

DIAGRAMAS.

DIAGRAMA DE CONTEXTO.

DIAGRAMA DE CONTEXTO



Este diagrama presenta una visión de alto nivel de la solución de la plataforma bancaria. Los actores principales y sistemas externos que intervienen e interactúan son los siguientes:

Cliente Bancario.

Corresponde al usuario final de la plataforma de banca digital. Este actor accede a la solución mediante los canales digitales (web y aplicación móvil) para realizar operaciones financieras, tales como:

- Consulta de información personal.
- Consulta de productos financieros.
- Consulta de movimientos bancarios.
- Transferencias internas.
- Transferencias interbancarias.
- Pago de servicios.

El cliente no interactúa directamente con ninguno de los sistemas corporativos del banco, sino únicamente con la Plataforma Banca Digital.

Plataforma Banca Digital.

Es el sistema base del presente diseño de arquitectura. Constituye el punto central de interacción entre el cliente y los sistemas internos y externos del banco.

Entre sus principales responsabilidades se encuentran:

- Gestionar la autenticación y autorización de los usuarios.
- Orquestar las consultas realizadas al Core Bancario.
- Obtener información complementaria desde sistemas externos.
- Ejecutar operaciones financieras.
- Solicitar el envío de notificaciones.
- Garantizar la auditoría y trazabilidad de todas las operaciones.

La plataforma proporciona una interfaz única y segura para los clientes, abstrayendo la integración con los distintos sistemas corporativos.

Core Bancario.

Representa el sistema transaccional principal de la entidad financiera. Es responsable de mantener la información financiera crítica del banco, incluyendo:

- Clientes.
- Cuentas.
- Productos Financieros.
- Movimientos.
- Transferencias.
- Saldos.
- Operaciones financieras.

La plataforma banca digital consulta este sistema para obtener la información base necesaria para ejecutar las operaciones financieras.

Sistema Externo.

Corresponde al sistema corporativo independiente encargado de administrar información complementaria del cliente. Su función es enriquecer la información obtenida desde el Core Bancario cuando una operación requiere información adicional. Esta integración permite mantener desacopladas las responsabilidades entre ambos sistemas.

Servicio de Notificación.

Corresponde a un sistema especializado encargado del envío de notificaciones a los clientes. La plataforma banca digital delega en este sistema el envío de notificaciones mediante diferentes canales como:

- Correo Electrónico
- SMS
- Notificaciones Push

Este desacoplamiento permite cambiar el proveedor de notificaciones sin afectar la lógica de negocio.

La arquitectura propuesta aplica el principio de desacoplamiento, evitando que el cliente interactúe directamente con los sistemas corporativos del banco.

La plataforma actúa como una capa de orquestación que centraliza toda la lógica de negocio y controla el acceso a los diferentes sistemas empresariales.

A continuación, se muestra un flujo general de la interacción:

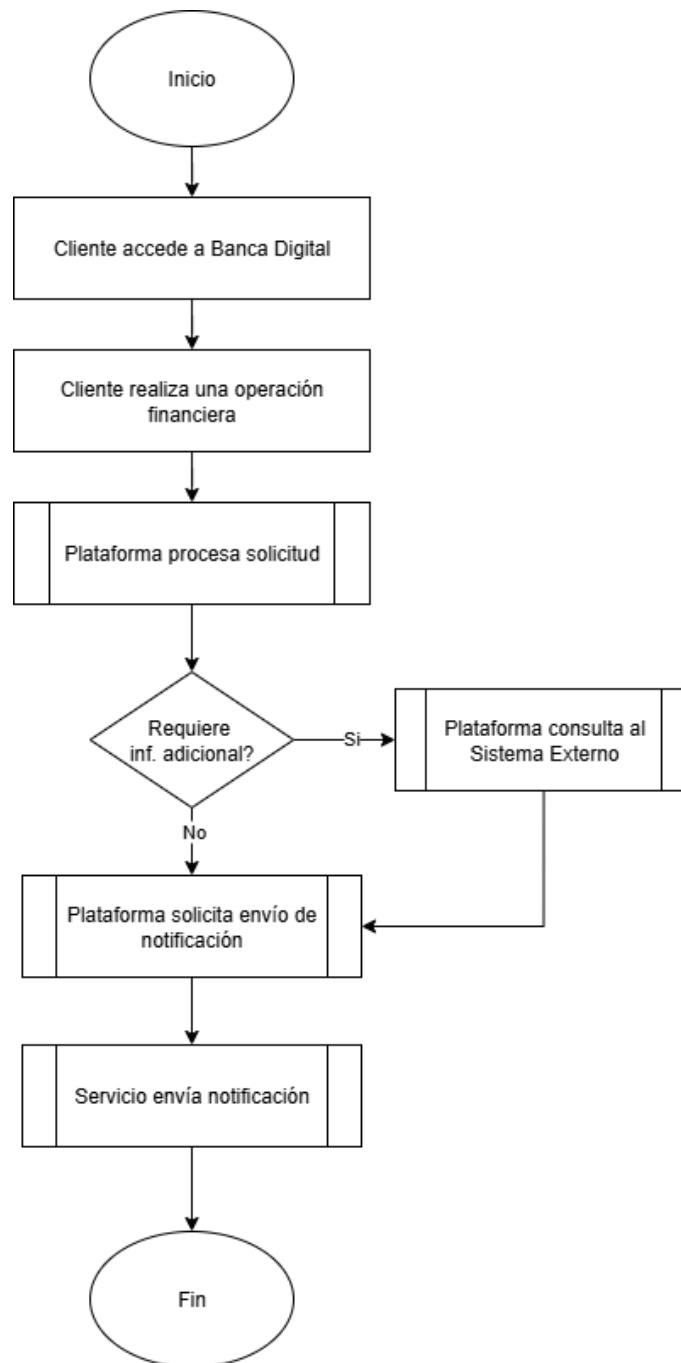
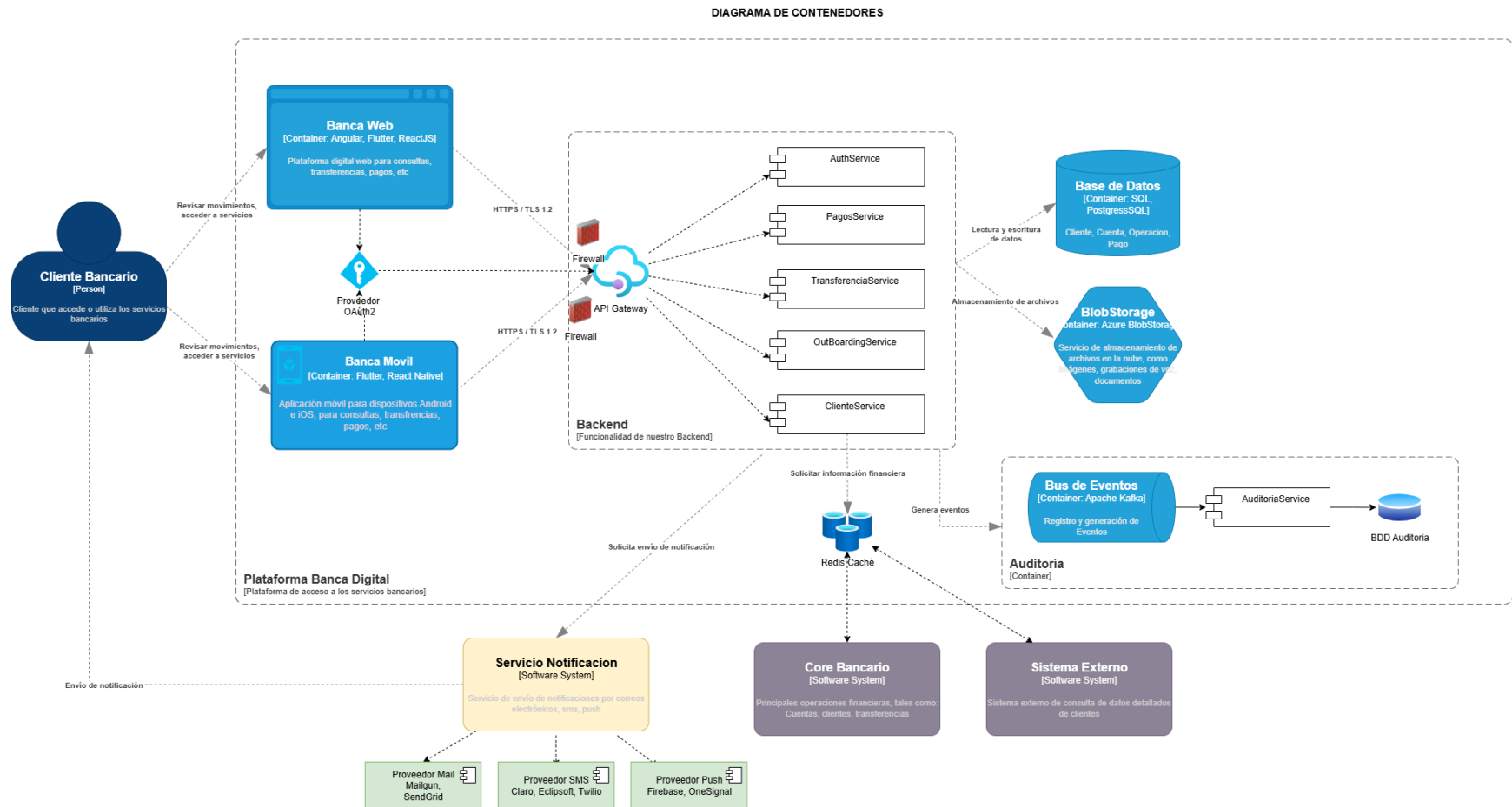


DIAGRAMA DE CONTENEDORES.



Este diagrama presenta la arquitectura lógica del sistema de banca digital, mostrando los principales contenedores que conforman la solución y las relaciones existentes entre ellos.

En este nivel se identifican las aplicaciones cliente, los servicios backend, la infraestructura de persistencia, los mecanismos de integración y los sistemas externos involucrados en la operación de la plataforma.

La arquitectura fue diseñada siguiendo principios de desacoplamiento, separación de responsabilidades, escalabilidad horizontal y alta disponibilidad, permitiendo la incorporación de nuevos servicios sin afectar el funcionamiento de los existentes.

Los actores que intervienen en el presente diagrama son los siguientes:

Cliente Bancario.

Al igual que en el diagrama anterior, representa el usuario final que utiliza los canales digitales del banco. Puede acceder a funcionalidades como:

- Consulta de información personal.
- Consulta de productos financieros.
- Consulta de movimientos.
- Transferencias internas.
- Transferencias interbancarias.
- Pago de servicios.

Toda la comunicación con la plataforma se realiza mediante conexiones seguras HTTPS utilizando TLS.

Banca Web.

Corresponde al sistema de banca web. Este sistema será implementado utilizando SPA (Single Page Application). Para este tipo de sistemas, se propone utilizar las siguientes tecnologías:

- **Angular.**

Se propone Angular ya que tiene las siguientes ventajas:

- Arquitectura modular.
- Excelente soporte para aplicaciones empresariales.
- Tipado fuerte mediante TypeScript.

- Facilidad para implementar componentes reutilizables.
- Integración sencilla con OAuth2.0 / OpenID Connect.
- Disponibilidad de amplia documentación y comunidad empresarial para soportes.

- **ReactJS.**

ReactJS es otra alternativa para la construcción de plataformas web, proporcionando las siguientes ventajas:

- Alto rendimiento en el proceso de renderizado del DOM.
- Facilidad para implementar componentes reutilizables.
- Amplia variedad de librerías, componentes y herramientas.
- Utilizado por organizaciones de gran escala.

La elección entre Angular o ReactJS no afecta el cumplimiento de los objetivos funcionales del sistema, ya que ambas tecnologías ofrecen las capacidades necesarias para desarrollar una plataforma web robusta, segura y escalable. Esta aplicación consume exclusivamente los servicios publicados por el API Gateway.

Banca Móvil.

Aplicación móvil multiplataforma. Las tecnologías propuestas para la construcción de la aplicación son:

- **Flutter.**

Las ventajas de implementar una aplicación móvil con Flutter, son las siguientes:

- Único desarrollo de código para plataforma Android e iOS.
- Excelente rendimiento.
- Interfaz de usuario consistente.
- Amplio soporte para autenticación biométrica.

- **React Native.**

Las ventajas de implementar una aplicación móvil con React Native, son las siguientes:

- Desarrollo multiplataforma, es decir, código único para Android y para iOS.
- Acceso a funcionalidades nativas del dispositivo.
- Dispone de gran cantidad de librerías para integrar servicios de terceros.

- Funcionalidad Hot Reload, que permite visualizar cambios en tiempo real durante el desarrollo.

La aplicación móvil también consume los servicios expuestos por el API Gateway mediante HTTPS.

Firewall.

Para realizar las peticiones desde el front-end hacia el API Gateway es necesario que todo el tráfico atravesase por un firewall o Web Application Firewall (WAF). Su función es proteger la plataforma frente a amenazas como:

- Ataques de fuerza bruta.
- SQL Injection.
- Cross Site Scripting (XSS).
- Ataque DDoS.
- Tráfico malicioso.

Este componente constituye la primera capa de defensa de la solución.

API Gateway.

Representa el punto único de entrada hacia todos los servicios del backend. Sus principales responsabilidades son:

- Enrutamiento de solicitudes.
- Validación de tokens OAuth2/JWT.
- Rate Limiting.
- Balanceo de carga.
- Versionamiento de APIs.
- Registro de métricas.
- Centralización de políticas de seguridad.

Esta capa evita que las aplicaciones cliente conozcan directamente la ubicación de los microservicios.

Backend.

El backend se encuentra compuesto por microservicios independientes que implementan una arquitectura desacoplada. Cada servicio posee una única responsabilidad funcional.

AuthService.

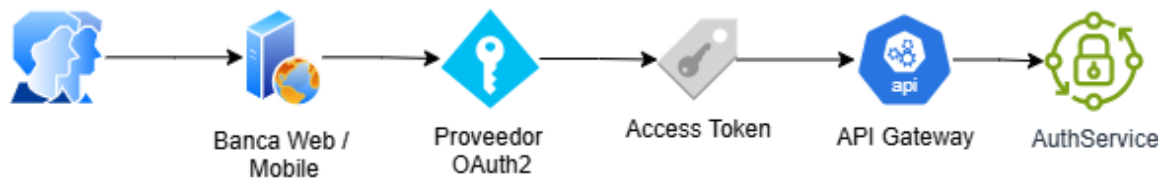
Responsable del proceso de autenticación y autorización. Sus funciones principales son:

- Validación de credenciales.
- Integración con proveedor OAuth2 / OpenID Connect.
- Emisión y validación de tokens JWT.
- Gestión de sesiones.
- Integración con autenticación biométrica en dispositivos móviles.

Este servicio concentra toda la lógica relacionada con identidad y acceso.

Se recomienda implementar el flujo Authorization Code con PKCE ya que es el mecanismo recomendado por OAuth2 para aplicaciones SPA y aplicaciones móviles. Este flujo permite que la autenticación sea realizada directamente por el proveedor de identidad, evitando que las credenciales del usuario sean procesadas por la aplicación cliente.

El flujo de autenticación quedaría de la siguiente manera:



Como proveedor OAuth2, se recomienda los siguientes:

Azure: Microsoft Entra ID

AWS: Amazon Cognito

ClienteService.

Gestiona toda la información asociada al cliente. Entre sus funciones se encuentran:

- Consulta de datos básicos.
- Consulta de información consolidada.

Cuando la información requerida no se encuentra en caché, realiza consultas al Core Bancario y al Sistema Externo.

TransferenciaService.

Responsable de ejecutar las transferencias financieras. Incluye procesos como:

- Validación de cuentas.
- Validación de saldo disponible.
- Validación de límites de transferencia.
- Ejecución de transferencias internas.
- Ejecución de transferencias interbancarias.

Una vez completada la operación, publica eventos hacia el bus de eventos para su posterior auditoría.

PagosService.

Administra las operaciones relacionadas con los pagos, como, por ejemplo: pago de servicios, pago de tarjetas, pago de créditos. Al igual que el servicio de transferencias, genera eventos para auditoría y notificaciones.

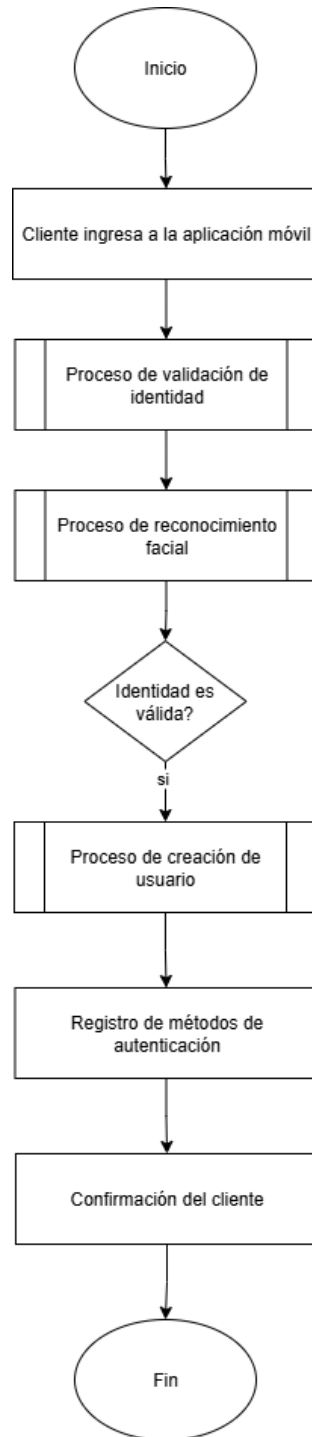
OnboardingService.

Gestiona el proceso de registro de nuevos clientes. Entre sus responsabilidades se encuentran:

- Registro Inicial.
- Captura Biométrica.
- Validación facial.
- Validación documental.
- Creación del usuario.
- Habilitación de métodos de autenticación.

Este servicio permite que nuevos clientes puedan registrarse completamente desde la aplicación móvil.

La siguiente imagen representa el flujo de OnBoarding el cual ocurre una única vez:



Bus de Eventos.

La plataforma incorpora Apache Kafka como bus de eventos. Su función principal consiste en desacoplar la ejecución de las operaciones financieras de los procesos secundarios.

Cada vez que ocurre un evento relevante, como una transferencia o un pago, el servicio correspondiente publica un evento que podrá ser consumido por otros componentes.

Esta estrategia permite implementar una arquitectura basada en eventos que es un patrón de diseño arquitectónico que permite la comunicación de los sistemas mediante eventos en lugar de llamadas directas entre servicios, proporcionando así un alto nivel de desacoplamiento, escalabilidad y resiliencia. Kafka es uno de los middlewares más utilizados para implementar este patrón.

Auditoría.

El contenedor de Auditoría está compuesto por:

- **AuditService.** Consume los eventos publicados en Kafka y registra forma persistente todas las acciones realizadas por los usuarios. Este mecanismo garantiza:
 - Trazabilidad
 - Cumplimiento regulatorio.
 - Historial de operaciones.
 - Evidencia para procesos de auditoría.

El desacoplamiento mediante eventos evita incrementar el tiempo de respuesta de las operaciones transaccionales.

- **BDD de Auditoría.** Base de datos independiente para registro y persistencia de logs de auditoría.

Base de Datos.

La solución utilizará una base de datos relacional (SQL Server o PostgreSQL) con el fin de almacenar la información operacional.

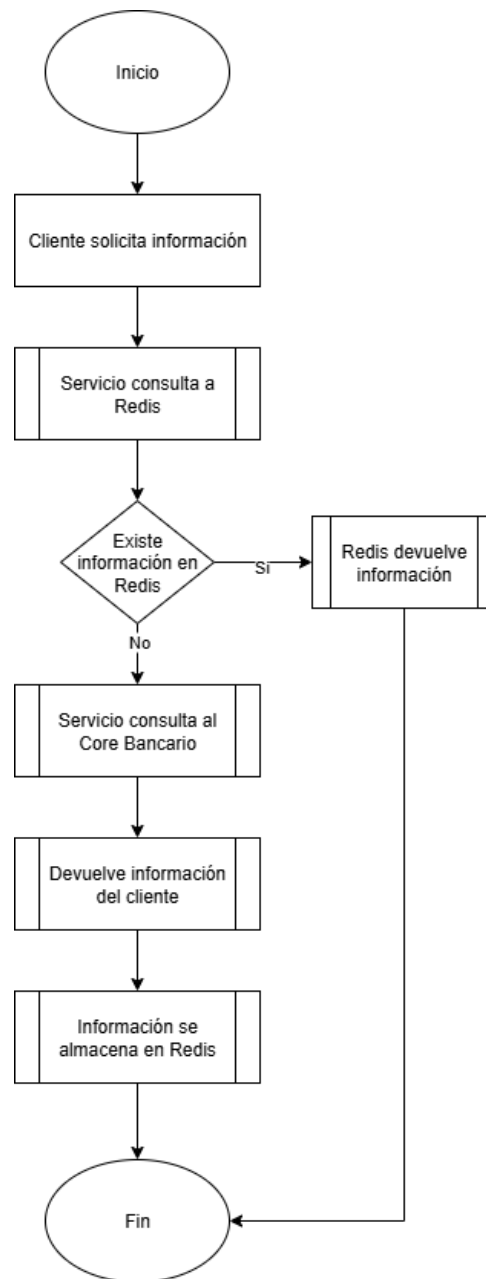
Cada microservicio accede a la información mediante sus propios repositorios, evitando el acceso directo entre servicios.

Azure Blob Storage.

Se propone Azure Blob Storage como repositorio de archivos. Su utilización permite almacenar información de gran tamaño sin impactar la base de datos relacional, tales como: documentos, fotografías, grabaciones, evidencias del proceso onboarding, comprobantes. Esta separación mejora el rendimiento y reduce el costo de almacenamiento.

Redis Caché.

Redis actúa como mecanismo de persistencia temporal para información consultada frecuentemente. Se implementa mediante el patrón Cache Aside, reduciendo significativamente la cantidad de consultas al Core Bancario. Este mecanismo reduce la latencia y mejora la experiencia del usuario. El flujo de funcionamiento es el siguiente:



Servicio de Notificación.

La solución integra un servicio especializado para el envío de notificaciones. Este servicio abstrae la integración con diferentes proveedores de comunicación. Los canales que soporta el servicio son:

- Correo Electrónico. Proveedores como Mailgun o SendGrid

- SMS. Proveedores como Twilio, Eclipssoft, MessagePlus
- Notificaciones Push. Proveedores como Firebase, Onesignal.

Esta arquitectura permite sustituir un proveedor sin afectar la lógica de negocio.

Core Bancario.

Representa el sistema transaccional principal de la institución financiera. Desde este sistema se obtiene información referente a Clientes, Cuentas, Productos, Movimientos, Transferencias, Saldos, etc.

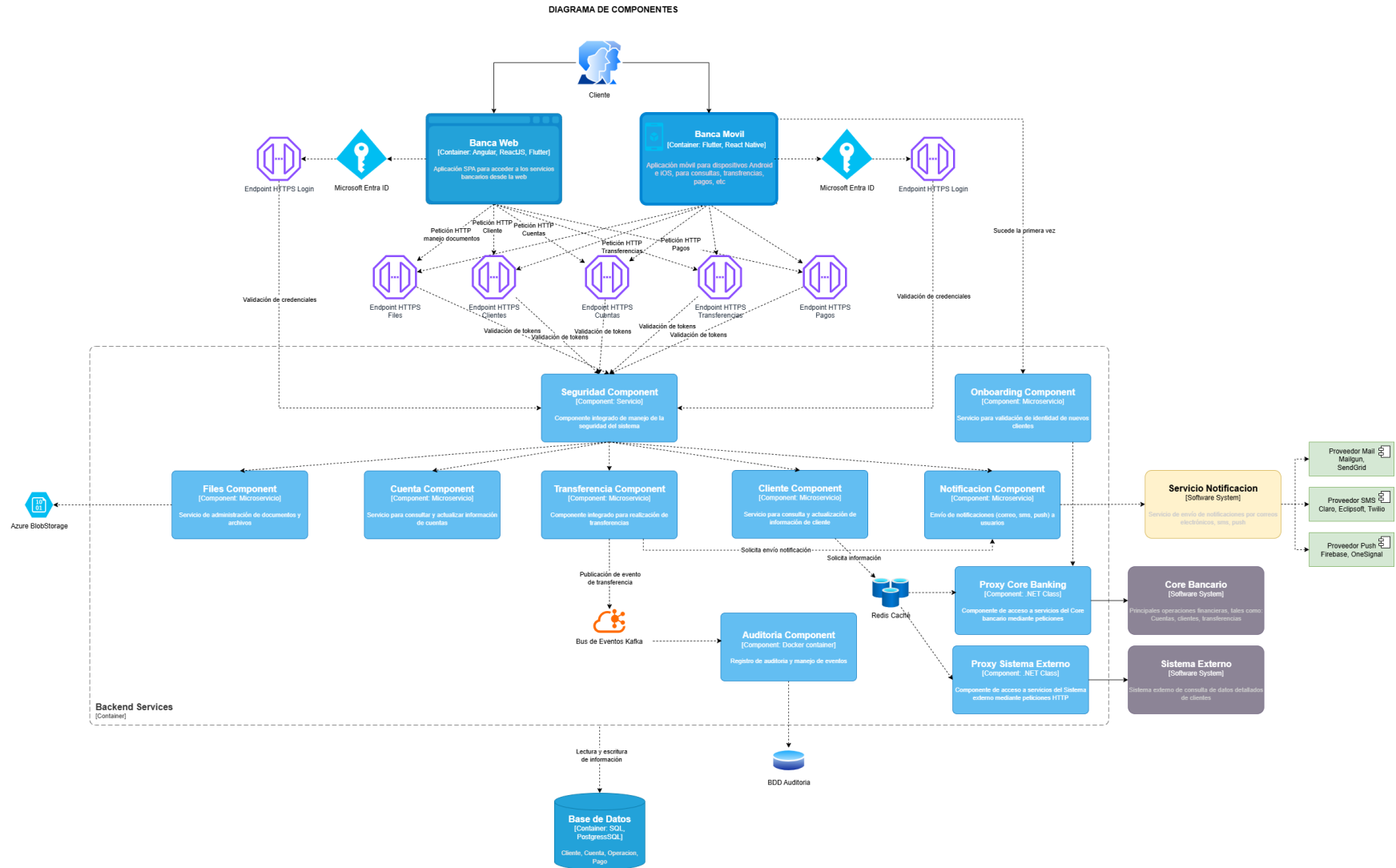
Sistema Externo.

Sistema especializado encargado de proporcionar información adicional del cliente que no se encuentra almacenada en el Core Bancario. La plataforma consulta este sistema únicamente cuando la operación requiere información complementaria.

En resumen, esta solución incorpora diversas decisiones orientadas a garantizar escalabilidad y mantenibilidad:

- **Microservicios**, para aislar responsabilidades y facilitar el despliegue independiente.
- **API Gateway**, como punto único de acceso y aplicación centralizada de políticas de seguridad.
- **Redis**, implementando el patrón Cache Aside, optimizando consultas frecuentes.
- **Apache Kafka**, para implementar una arquitectura orientada a eventos (Publish/Subscribe), desacoplando procesos como auditoría y notificaciones.
- **Azure Blob Storage**, para almacenar archivos de gran tamaño sin sobrecargar la base de datos.
- **OAuth 2.0/OpenID Connect**, para autenticación segura y estandarizada.
- **Separación de responsabilidades**, donde cada servicio se enfoca en una única capacidad de negocio.

DIAGRAMA DE COMPONENTES.



Este diagrama representa la estructura interna de nuestro Backend para la plataforma de banca digital. Se muestra cómo se distribuyen las responsabilidades entre los diferentes componentes del sistema y cómo interactúan entre sí para ofrecer los servicios de consulta, autenticación, transferencias, pagos, gestión documental, auditoría y notificaciones.

Esta arquitectura adoptada se basa en componentes desacoplados, permitiendo que cada uno evolucione de forma independiente y favoreciendo la reutilización, escalabilidad y mantenibilidad de la plataforma.

Enseguida detallaremos cada uno de los componentes utilizados en el diagrama:

Cliente.

Representa el usuario final que utiliza los canales digitales del banco. Puede acceder a funcionalidades como:

- Consulta de información personal.
- Consulta de productos financieros.
- Consulta de movimientos.
- Transferencias internas.
- Transferencias interbancarias.
- Pago de servicios.

Banca Web.

Corresponde a la aplicación SPA desarrollada usando tecnologías como Angular o ReactJS. Su responsabilidad consiste en proporcionar la interfaz de usuario para el acceso desde navegadores web. Todas las solicitudes realizadas por la aplicación son enviadas mediante HTTPS hacia los endpoints del API Gateway.

La autenticación se delega completamente al proveedor de identidad Microsoft Entra ID utilizando OAuth2

Banca Movil.

Corresponde a la aplicación móvil desarrollada con frameworks multiplataforma como son Flutter o ReactNative. Incorpora capacidades propias de dispositivos móviles como: Huella digital, Face ID, Reconocimiento facial, Notificaciones Push.

Microsoft Entra ID.

Actúa como Identity Provider (IdP) de la solución. Es el encargado de las siguientes responsabilidades:

- Autenticar al usuario.
- Validar credenciales.
- Aplicar políticas de seguridad.
- Gestionar sesiones.
- Emitir Access Token JWT.
- Gestionar autenticación multifactor (MFA).

La plataforma delega completamente el proceso de autenticación al proveedor, evitando almacenar contraseñas dentro de la aplicación.

Endpoint HTTPS Login.

Representa el punto de entrada utilizado por Microsoft Entra ID para completar el flujo de Authorization Code + PKCE. Este endpoint recibe el código de autorización emitido e inicia la generación de la sesión del usuario.

Endpoints HTTPS Operacionales.

Cada endpoint representa el punto de entrada para una capacidad funcional expuesta mediante el API Gateway.

Seguridad Component.

Es el componente transversal encargado de centralizar todas las políticas de seguridad de la plataforma. Sus principales responsabilidades son:

- Validación de Access Tokens.
- Validación de JWT.
- Validación de permisos.
- Control de autorización.
- Verificación de roles.
- Aplicación de políticas de acceso.

Todos los puntos de conexión (endpoints) consumen este componente antes de ejecutar cualquier operación de negocio, evitando duplicidad de lógica de seguridad en cada operación y garantizar un comportamiento uniforme.

Onboarding Component.

Administra el proceso de incorporación de nuevos clientes. Solo participa cuando el usuario utiliza la aplicación por primera vez. Sus principales responsabilidades son:

- Captura de información personal.
- Validación de identidad.
- Reconocimiento facial.
- Validación biométrica.

Y una vez realizado el proceso el usuario podrá realizar la autenticación utilizando credenciales, huella digital o Face ID.

Los demás componentes fueron explicados en el diagrama anterior.

ARQUITECTURA DE MONITOREO.

El monitoreo de rendimiento y observabilidad de las aplicaciones es muy importante en todo diseño arquitectónico. Por lo cual, en esta propuesta, se recomienda usar los siguientes componentes en la nube de Azure para realizar monitoreo tanto de la aplicación como de infraestructura.

Azure Application Insights.

Es el componente encargado del monitoreo de la aplicación. Recolecta automáticamente información como:

- Tiempos de respuesta.
- Solicitudes HTTP.
- Errores.
- Consumo de recursos.

También se puede registrar automáticamente llamadas hacia SQL, Redis, Kafka, Azure Blob Storage.

Azure Monitor.

Centraliza la información de todos los componentes de la plataforma, ya que permite supervisar: Máquinas Virtuales, Kubernetes, Bases de Datos, Balanceadores, Redes, Aplicaciones, Api Gateway.

AUTORIZACIÓN Y CONSENTIMIENTO DE USO DE DATOS PERSONALES.

Con el objetivo de cumplir los principios establecidos por la Ley Orgánica de Protección de Datos Personales y evitar la duplicidad de lógica entre los diferentes componentes del sistema, se propone incorporar un componente independiente denominado Consentimiento y Protección de Datos.

Este componente centralizará la administración de las autorizaciones otorgadas por los clientes para el tratamiento de sus datos personales, permitiendo que todos los servicios de la plataforma consulten una única fuente de verdad antes de utilizar información considerada sensible o antes de compartirla con sistemas internos o proveedores externos.

Gracias a esta centralización, los componentes funcionales como Cliente, Transferencias, Pagos o Notificaciones no implementan lógica específica relacionada con el tratamiento de datos personales, sino que delegan esta responsabilidad al componente especializado, promoviendo el desacoplamiento, la reutilización y una administración uniforme de las políticas de privacidad.

RESUMEN DE PROPUESTA.

La arquitectura propuesta para la plataforma de banca digital fue diseñada siguiendo los principios de una arquitectura moderna, escalable y desacoplada, utilizando el modelo **C4** para representar los niveles de contexto, contenedores y componentes. La solución integra aplicaciones web y móvil, un backend basado en microservicios, mecanismos de autenticación mediante **OAuth 2.0/OpenID Connect** con Microsoft Entra ID, integración con el Core Bancario y sistemas externos mediante componentes proxy, además de servicios especializados para notificaciones, auditoría y gestión documental.

Como parte de la optimización y resiliencia de la plataforma, se incorporan **Redis Cache** para mejorar el rendimiento de las consultas frecuentes, **Apache Kafka** para el procesamiento

desacoplado de eventos de auditoría, **Azure Blob Storage** para el almacenamiento seguro de archivos y documentos, así como **Azure Monitor** y **Application Insights** para el monitoreo y la observabilidad de la solución.

Adicionalmente, la arquitectura detalla la construcción de un **Componente Centralizado de Gestión de Consentimiento y Protección de Datos Personales**, encargado de administrar las autorizaciones y revocatorias del tratamiento de datos personales de los clientes, garantizando el cumplimiento de la **Ley Orgánica de Protección de Datos Personales (LOPD)** y promoviendo una gestión uniforme de las políticas de privacidad en todos los servicios de la plataforma.

En conjunto, la solución contempla principios de alta disponibilidad, tolerancia a fallos, seguridad, monitoreo, escalabilidad y facilidad de mantenimiento, permitiendo la incorporación de nuevas funcionalidades sin afectar la arquitectura existente y garantizando el cumplimiento de las regulaciones y buenas prácticas del sector financiero.